

1. WHOIS – Identificación del propietario IP

Comando ejecutado:

```
whois 192.168.1.3
```

¿Qué hace?

Consulta a los registros globales para saber quién es el propietario del bloque IP. En este caso, devuelve:

```
NetName: PRIVATE-ADDRESS-CBLK-RFC1918-IANA-RESERVED
```

Explicación:

La IP **192.168.1.3** es una IP privada definida por el RFC 1918. No tiene dueño público porque está destinada para redes locales. Es común en entornos de pruebas o laboratorios internos.

Enseñanza:

Los rangos **192.168.x.x**, **10.x.x.x**, y **172.16.x.x** a **172.31.x.x** son privados. WHOIS no devolverá propietarios válidos en estos casos.

2. NSLOOKUP – Resolución DNS inversa

Comando ejecutado:

```
nslookup 192.168.1.3
```

Resultado:

```
name = blandskron-iris.local
```

Explicación:

Nos dice cómo se llama el equipo que tiene esa IP. Útil para identificar objetivos por nombre de host.

Enseñanza:

Una máquina puede tener un nombre que delate su uso o dueño, por ejemplo: **admin-workstation**, **kali-vm**, etc.

3. DIG – Resolución DNS avanzada

Comando ejecutado:

```
dig -x 192.168.1.3
```

Resultado:

PTR -> blandskron-Iris, blandskron-Iris.local

Explicación:

Verifica los registros PTR (punteros) que asocian IPs a nombres. Similar a `nslookup` pero más detallado y usado profesionalmente.

Enseñanza:

`dig` es útil en entornos donde `nslookup` no es suficiente o no responde. Ideal para debugging DNS.

4. NMAP – Escaneo de puertos y servicios

Comando ejecutado:

```
nmap -sS -sV -T4 -p- 192.168.1.3
```

¿Qué hace?

- `-sS`: escaneo SYN (sigiloso)
- `-sV`: detección de versiones
- `-T4`: velocidad de escaneo (más rápida)
- `-p-`: escanea todos los 65535 puertos TCP

Resultado relevante:

9000/tcp open http Gophish httpd

8080/tcp open Apache httpd 2.4.25 (Debian)

8083/tcp open Apache Tomcat

3000/tcp open OWASP Juice Shop

Explicación:

Hay múltiples servicios web en diferentes puertos. El puerto 3000 corresponde a OWASP Juice Shop, una app vulnerable ideal para practicar.

Enseñanza:

nmap es la base del escaneo ético. Permite saber qué puertas están abiertas, qué servicios hay y en qué versión (lo que puede llevar a vulnerabilidades).

5. NIKTO – Detección de vulnerabilidades web básicas**Comando ejecutado:**

```
nikto -h http://192.168.1.3:9000
```

Resultado:

- + X-Frame-Options no presente → Riesgo de Clickjacking
- + Uncommon header x-csrf-token → Posible CSRF detectable
- + X-Content-Type-Options no presente → Riesgo de MIME Sniffing

Explicación:

Nikto analiza configuraciones débiles en la cabecera HTTP, que pueden dar lugar a ataques como:

- **Clickjacking:** incrustar tu sitio en un iframe y engañar al usuario.
- **CSRF:** manipulación de acciones con la sesión activa de un usuario.
- **MIME Sniffing:** ejecución de scripts por contenido mal definido.

Enseñanza:

Nikto no explota, solo informa. Pero es útil para iniciar análisis técnico y priorizar fallas sencillas.

Recomendación

1. Siempre realizar `whois`, `nslookup` y `dig` para reconocer el entorno.
2. Usar `nmap` con todos los puertos antes de cualquier análisis web.
3. Confirmar las cabeceras inseguras con `nikto`, y luego profundizar con `Burp Suite` o `ZAP`.
4. Nunca asumir que un solo escaneo es suficiente. Usar múltiples herramientas.
5. Registrar todo en bitácora técnica.

